

프로젝트 기획서

기업용 AI Agent 실행 보안과 내부 표현 기반 위험 탐지

Commercial Direction / Research-backed MVP

01 프로젝트 정의

Argus-V는 Agent의 도구 실행을 기업 정책에 따라 허용·차단·승인 대기로 분기하고, 내부 상태에 접근 가능한 모델에서는 Activation 기반 위험 신호를 추가하는 실행 보안 계층이다. 기본 보안 기능은 Probe 없이도 작동하도록 설계한다.

항목	이번 프로젝트의 결정
첫 업무	사내 문서 검색 → 보고서 작성 → 모의 이메일 발송
고객 가설	자체 모델로 사내 업무 Agent를 구축·운영하는 개발·보안 팀
기간 / 팀	2026.09.22 ~ 10월 마지막 주 / 4명
제품 핵심	정책 검사, 실행 통제, 승인, 결정 이유와 감사 로그
차별화 가설	행동 문맥에 내부 표현을 추가하면 위험 누락 또는 정상 업무 방해가 줄어드는가?
현재 상태	설계 단계. 구현, 실험 성능, 고객 수요·지불 의사 모두 검증 전

02 방향 변경의 의미

기존의 Activation Probe 중심 연구를 제품 전체의 차별화 실험으로 재배치한다. 이번 산출물은 작은 통합 MVP와 비교 실험이며, 범용 SaaS나 두 개의 독립 제품을 동시에 만들지 않는다.

기존 문서와 대화를 반영한 개정본. 원본의 연구 질문·실험 재현성 원칙은 유지하고 제품 우선순위와 담당 범위를 변경했다.

고객 문제와 MVP 범위

모델의 일반적인 안전성보다 회사별 권한·자료 취급·승인 규칙을 실제 행동에 적용하는 문제에 집중한다.

03 검증할 업무 시나리오

상황	기대 동작
정상 업무	권한이 있는 문서로 보고서를 만들고 허용된 수신자에게 발송
권한 밖 문서 접근	명시적인 접근 정책으로 차단
자료 반출 / 승인 누락	허용되지 않은 수신자 발송은 차단, 승인 필수 발송은 대기
외부 문서의 유도 지시	문서 내용을 상위 지시로 따르는 행동이 나타나는지 문맥·내부 신호로 평가
처음 보는 문서·업무 변형	새 시나리오에서 오탐·미탐과 정상 작업 성공률 측정

04 구현할 것 / 미룰 것

- 필수: 하나의 Agent 연동, 모의 문서·수신함, 도구 실행 래퍼, 규칙 기반 정책, 승인·차단, 감사 로그.
- 필수: open-weight 모델의 Probe, 정책/문맥/내부 신호의 추가 효과 비교, OOD 평가와 재현 가능한 데모.
- 후속: 여러 모델·프레임워크 연동, 실제 메일 발송, 멀티테넌트 SaaS·결제, 복잡한 운영 대시보드.

05 상업성 검증

잠재 사용자 3~5명 인터뷰를 목표로 현재 막힌 Agent 도입 사례, 기존 승인 부담, 필요한 배포 방식, 내부 상태 접근 가능 여부를 조사한다. 문서·데모를 보고 파일럿을 시도할 의사가 있는지도 기록한다. 인터뷰 수만으로 시장 수요가 입증된 것으로 보지 않는다.

대상 고객과 인터뷰 수는 실행 가설이다. 가격·시장 규모·매출 전망은 현재 확정하지 않는다. 팀이 인터뷰를 진행하며, 이 문서는 외부 연락 실행을 의미하지 않는다.

제품 구조와 실행 계약

기본 실행 통제 위에 행동 문맥과 내부 신호를 추가한다. Probe 장애나 미탐재가 명시적인 보안 정책의 해제를 의미하지 않도록 설계한다.

06 한 실행 경로, 두 가지 감시 입력

Agent → 제안된 Tool Call → 정책·권한 검사 + 행동 문맥 검사 + 선택적 Activation 점수 → ALLOW / BLOCK / REQUIRE_APPROVAL → 모의 도구 실행 → 감사 로그

구성요소	계약과 책임
Execution Guard	실제 도구는 Guard만 호출한다. 호출 주체·권한은 모델 생성 인자가 아니라 신뢰된 실행 환경에서 가져온다.
Policy Engine	명시적인 금지 정책은 Probe 점수와 무관하게 차단한다. 승인 규칙·정책 버전을 기록한다.
Context Monitor	현재 Tool 인자와 이전 행동·문서 출처를 사용한다. 완료되지 않은 미래 정보는 사용하지 않는다.
Activation Adapter	모델별 hook·관찰 시점·Probe 버전과 점수를 전달한다. 내부 접근이 없는 모델에는 점수를 제공하지 않는다.
Approval / Audit	승인은 실행 ID·도구·인자에 연결한다. 인자 변경 시 재검사하고 재사용·중복 실행을 방지한다.

07 최소 데이터와 장애 처리

실행·시나리오 ID, 도구·인자 식별값, 정책 버전, 결정·이유, 승인 상태, Probe 버전·점수, 실행 여부·결과, 시간 정보를 연결한다. 실행 직전 현재 권한을 재확인한다. 필수 검사 실패·승인 대기 상태에서는 해당 고위험 행동을 실행하지 않는다.

초기에는 익명·가상 자료로 검증한다. 원문·비밀값의 로그 저장을 최소화하고, Activation을 익명 데이터로 가정하지 않는다. 실운영의 보관 기간·접근 제어는 파일럿 설계에서 확정한다.

비교 실험과 성공 판단

제품 가치와 내부 신호의 추가 기여를 분리해서 검증한다. 단순한 차단 데모나 몇 토큰 빠른 경고만으로 차별화를 주장하지 않는다.

실험 구성	검증 목적
E0: 통제 없음	격리된 Sandbox에서 위험 시도·실행의 기준값
E1: 정책만	명시적 권한·승인·수신자 규칙의 효과
E2: 정책 + 행동 문맥	Tool 인자와 과거 문맥을 더한 효과
E3: E2 + Activation	내부 표현의 추가 효과. E2와 동일한 관찰 시점·조건으로 비교

08 핵심 지표

위험 실행률 = 위험 행동 제안 중 실제 실행된 비율. 정상 업무 성공률 = 정상 업무 중 정책을 지키며 완료한 비율.
승인 요청률 = 검사한 행동 중 사람 승인을 요청한 비율. AUROC/AUPRC, 고정 임계값 Recall·FPR, p50/p95 추가
지연과 실행당 비용도 함께 기록한다.

09 공정한 평가

- 동일 trajectory와 유사 시나리오 계열은 split 사이에 섞지 않는다. 레이어·결합·임계값은 Validation에서 선택한다.
- Tool Call 생성 전 조기 예측과 생성 후·실행 전 판별을 별도 보고한다. 미래 토큰·실행 결과는 입력에서 제외한다.
- E2와 E3는 같은 데이터·행동 후보로 오프라인 비교하고, Gate로 행동이 달라지는 효과는 별도 온라인 반복 실행으로 측정한다.
- 낮은 FPR 목표는 Validation에서 정한다. Test의 실제 FPR·Recall, 표본 수와 trajectory 단위 불확실성을 보고한다.

10 채택 기준

파일럿에서 합의한 정상 업무·승인 부담·지연 예산 안에서 E3가 E2보다 반복 가능한 개선을 보일 때 내부 감시를
제품 차별점으로 채택한다. 수치 목표는 초기 기준선과 인터뷰 후, 최종 평가 전에 고정한다. 개선이 없으면 연구
한계로 보고하고 필수 기능으로 강제하지 않는다.

4인 역할과 C 연구 오너십

C 담당은 저장소 소유자 ljl5489가 맡는다. 역할명뿐 아니라 설계·코드·비교 실험·실패 분석까지 연결해 개인 기여를 남긴다.

담당	주요 책임 / 경계
A · 시스템	Guard, 정책 적용, 승인 상태, 감사 로그, 전체 통합. 백엔드·코딩 강점 활용.
B · 환경·데이터	모의 문서·발송 도구, 정책·시나리오, 행동 정답과 데이터 검수.
C · ljl5489	표현 추출 adapter-hook, Linear Probe, 다중 레이어·시점 분석, OOD·실패 유형별 탐지 분석.
D · 평가·제품 검증	공통 지표·E0~E3 평가 도구, 최종 split 관리, 운영 지표·데모 검증, 인터뷰 근거 정리.

11 C의 필수 연구 산출물

- 모델별 표현 추출 명세와 구현: 블록·토큰·pooling·정밀도·revision을 기록한다. A는 실행 환경과 Guard 연결을 지원한다.
- Linear Probe 및 Single / Top-3 / All 비교: 용량·학습 조건을 공개하고 검증 데이터에서 감시 지점을 선택한다.
- 위협 유형·미지 시나리오별 성능, 정상 과잉 차단, 미탐 분석. C가 분석을 주도하고 D가 독립 평가를 재실행한다.
- 레이어×시점 성능 그림, 오탐·미탐 사례 보고서, E2 대비 E3 기여 실험과 연결된 PR·실험 ID.

12 CV와 AI 보안 포트폴리오 연결

AI 보안 근거는 위협 모델, 정책 위반 탐지, 공격·OOD 조건의 강건성 평가다. CV와 연결되는 역량은 Transformer 표현 추출, feature probing, 이상·분포 변화 분석이다. 현재 LLM 결과를 CV 실험 성과로 표기하지 않는다. 직접적인 CV 증거는 별도 ViT 실험으로 확보한다.

A↔C는 모델·통합을, B↔D는 라벨·평가를 교차 리뷰한다. C는 최종 Test를 이용해 모델을 선택하지 않는다. 각 담당자가 자신의 코드와 문서를 작성한다.

제출물과 확장 원칙

10월 말에는 재현 가능한 보안 MVP와 실험 근거를 제출한다. 화면 수보다 정상 업무와 위험 행동이 어떻게 처리 되는지, 내부 신호가 어떤 추가 가치를 주는지가 중요하다.

13 C의 선택적 CV 실험

10월 18일까지 통합·핵심 평가가 안정된 경우에만 C와 D가 범위를 확정한다. 고정된 ViT의 블록별 표현으로 Linear Probe를 비교하고, 이미지 변형·미지 범주에서 분포 변화 탐지와 정확도 저하를 분석한다. 이미지 단위 누수를 방지하고 ID/OOD·학습/검증/평가를 분리한다.

별도 노트북과 보고서로 공개하며 LLM Probe를 그대로 전이했다고 주장하지 않는다. 데이터 이용 조건과 특징 차원을 별도 확인한다. 시간이 부족하면 10월 이후 후속 과제로 둔다. VLM의 이미지 기반 prompt injection은 그 다음 단계다.

14 최종 제출 체크리스트

- 정상 실행, 정책 차단, 승인 대기·승인 후 실행, 승인 인자 변경 재검사의 데모.
- E0~E3 비교표, 시나리오별 실패 분석, 정상 업무·승인 요청·지연 지표.
- 코드 commit, 모델·데이터·정책 버전, split, seed, 환경을 연결한 재현 안내.
- 고객 문제·도입 조건·파일럿 의향의 인터뷰 요약. 사실과 가설을 분리한다.
- 개인별 문제 → 설계 → PR → 실험 → 결과·한계 기록. 계획을 완료 성과로 쓰지 않는다.

15 참고와 변경 기록

개정 근거: 기존 Argus-V 프로젝트 기획서·발전 로드맵과 2026.09.22 대화. 변경: 실행 보안 우선, Activation 선택 모듈화, 업무·고객 가설 구체화, C 오너십과 CV 후속 실험 명시.

기존 도구의 실행 전 승인·검사 기능은 이미 존재한다. 차별점은 추가 효과로 검증한다. 참고: LangChain Human-in-the-loop middleware

https://reference.langchain.com/python/langchain/agents/middleware/human_in_the_loop

NVIDIA NeMo Guardrails Overview

<https://docs.nvidia.com/nemo/guardrails/about-nemo-guardrails-library/overview>